AI 코드 검수 결과

가상 프로젝트 예시 · 합성 코드 · 결과물 형식 시연

샘플 안내 이 문서는 결과물의 구성과 설명 방식을 보여주기 위해 수작업으로 만든 예시입니다. 실제 고객 저장소나 Gemini 실응답을 사용하지 않았습니다.

검수 대상	우선 확인	실행 범위
demo/invoice.py **가상 Python · 8줄**	**HIGH 1건** **MEDIUM 1건**	**코드/테스트 실행 안 함** **배포 환경 미확인**

먼저 확인할 항목

HIGH SQL 쿼리에 사용자 입력이 문자열로 포함됩니다

위치 demo/invoice.py:2-3

```
query = f"SELECT * FROM invoices WHERE id = {invoice_id}"
row = db.execute(query).fetchone()
```

영향 입력값 검증이 없으면 쿼리 문자열이 변형되어 의도하지 않은 데이터 조회로 이어질 수 있습니다.

권고 DB 드라이버의 파라미터 바인딩으로 실행하고, 입력 형식도 검증하세요.

확인 수준 합성 예시입니다. 실제 DB 드라이버와 호출부는 검수하지 않았습니다.

추가 검토와 다음 작업

발견은 코드 근거와 확인 범위를 함께 적고, 맥락이 필요한 항목은 조건부 위험으로 표시합니다.

MEDIUM 청구서 소유자 확인 조건이 보이지 않습니다

위치 demo/invoice.py:1-8

```
def get_invoice(invoice_id, current_user_id):
    query = f"SELECT * FROM invoices WHERE id = {invoice_id}"
    row = db.execute(query).fetchone()
    if row is None:
        return None
    return row
```

근거 함수는 current_user_id를 받지만 조회 조건에는 소유자(owner_id) 제한이 없습니다.

영향 호출 경로에서 별도 권한 검사가 없다면 다른 사용자의 청구서가 반환될 수 있습니다.

권고 조회에 소유자 조건을 포함하고, 사용자 A가 사용자 B의 ID를 요청할 때 거부되는 테스트를 추가하세요.

확인 수준 인증 미들웨어와 호출부가 빠진 가상 예시이므로 실제 권한 누락 여부는 조건부 위험입니다.

권장 작업 순서

1	SQL 파라미터 바인딩 적용
2	조회에 사용자 소유권 조건 추가
3	정상 사용자와 타 사용자 ID를 이용한 회귀 테스트 작성
4	수정된 함수와 실제 호출부를 다시 검수

검수 범위와 한계

이 샘플은 리포트의 형식과 설명 방식을 보여줍니다. 실제 판매 결과는 고객이 제공한 지원 파일과 합의된 범위에 한정하며, 코드 실행·테스트·침투 테스트·서버 설정 확인·보안 인증·무결점 보증을 제공하지 않습니다. AI 제안의 파일·줄·발췌 일치만으로 결함 자체가 증명되지는 않으며, 중요 항목은 사람이 원본과 맥락을 대조합니다.